

CSIT302 Cybersecurity

Day 5-3 – Recovery Process

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Overview: Disaster Recovery

- Disaster recovery plan
- Live recovery
- Contingency plan
- Best practices for recovery

Disaster Recovery Plan

- **The disaster recovery plan**

- A documented set of processes and procedures that are carried to recover **the IT infrastructure** in the event of a disaster.
- It is impossible to avoid all disasters; the best to do is plan ahead how to recover if disasters happen.

- Natural and Man-made disasters

- Natural disasters are ones that result from environmental hazards or acts of nature. (e.g., blizzards, wildfires, hurricanes, volcanic eruptions, earthquakes, floods, and lightning strikes.)
- Man-made disasters are ones that arise from the actions of human users or external human actors. (e.g., fires, cyber warfare, hacking, power surges, and accidents.)

- The objective of the disaster recovery plan

- To protect the continuity of business operations when IT operations have been partially or fully stopped

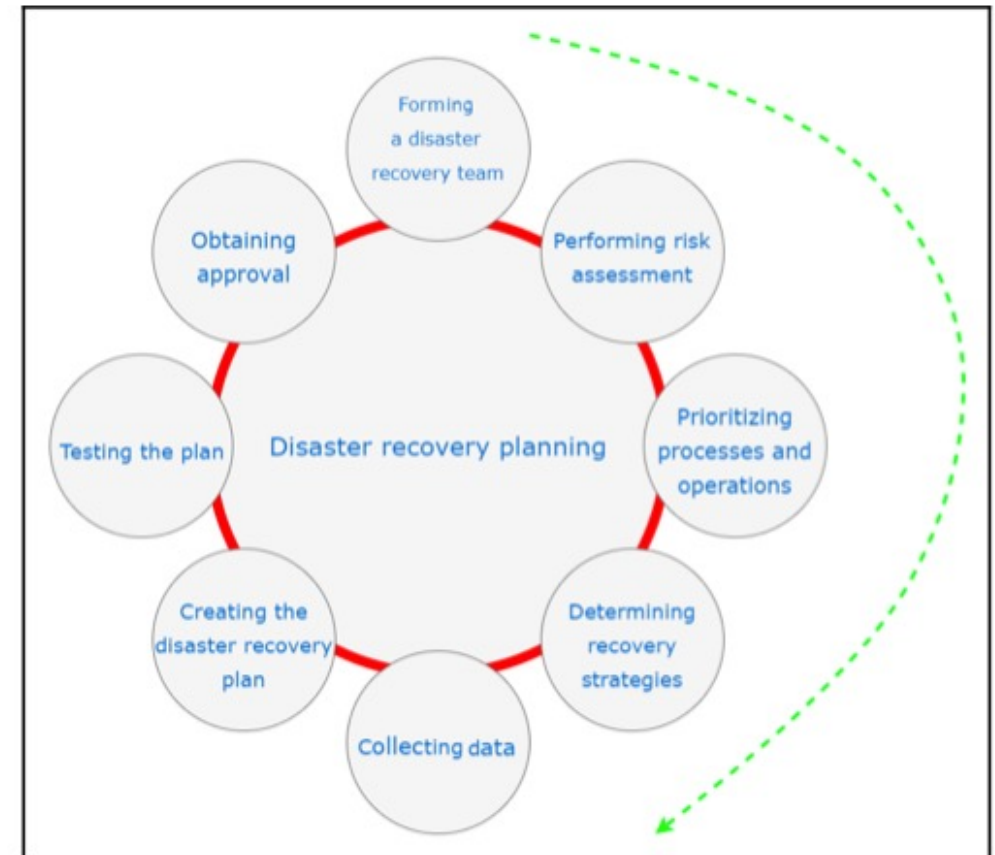
Disaster Recovery Plan

- Benefits of having a disaster recovery plan in the organization
 - Having a sense of security: The recovery plan assures the continued ability to function in the face of a disaster.
 - Reducing delays in the recovery process: Without a sound plan, it is easy for the disaster recovery process to be done in an uncoordinated way, thereby leading to delays.
 - Guaranteed reliability of standby systems: The plan ensures that standby systems are always prepared to take over to restore business operations during disasters.
 - Providing a standard test plan for all business operations.
 - Minimizing the time taken to make decisions during disasters.
 - Mitigating legal liabilities that the organization could develop during a disaster.

Disaster Recovery Plan

- Disaster recovery planning process

1. Forming a disaster recovery team
2. Performing risk assessment
3. Prioritizing processes and operations
4. Determining recovery strategies
5. Collecting data
6. Creating the disaster recovery plan
7. Testing the plan
8. Obtaining approval



Disaster Recovery Plan

1. Forming a disaster recovery team

- A **disaster recovery (DR)** team: The team that is formed to assist the organization with all the disaster recovery operations.
- The DR team should be all-inclusive, involving members from all departments and some representatives from top-level management.
- This team will determine the scope of the recovery plan regarding the operations that they carry out in their individual departments.
- The team will also oversee the successful development and implementation of the plan.

Disaster Recovery Plan

2. Performing risk assessment

- The DR team should conduct a risk assessment man-made risks that could affect organization the IT infrastructure.
- The DR team should also evaluate the security listing the threats that they are exposed to and have.
- At the end of the risk assessment exercise, the organization will be aware of the impacts and consequences of many threats. A thorough disaster recovery plan will be made for each case scenario.

Risk	Possibility 0 - Not Likely 1 - Very Low 2 - Medium 3 - High 4 - Very High	Impact 0 - None 1 - Some 2 - Moderate 3 - Significant 4 - Severe	Score
Cyber Attack			
Earthquake			
Facility Fire			
Flood			
Forest Fire			
Hazmat			
Hurricane			
Sabotage			
Terrorist Attack			
Tornado			
Total Risk Score			

Multiply Possibility by Impact to score

0 - 25 Low
26 - 40 Moderate - DRP / BCP should be considered
40 - 60 Considerable - DRP / BCP highly recommended
60 and up - http://www.e-janco.com/DisasterPlanning.htm



Disaster Recovery Plan

3. Prioritizing processes and operations

- The representatives from each department in the disaster recovery plan identify their **critical needs** that should be **prioritized** in the event of a disaster.
 - ✓ Since most organizations will not possess sufficient resources to respond to all the needs that arise during disasters, some criteria need to be set in order to determine which needs require the organization's resources and attention first.
- The **key areas** that need to be prioritized in the making of a disaster recovery plan include functional operations, information flow, accessibility and availability of the computer systems used, sensitive data, and existing policies.

Disaster Recovery Plan

- The team needs to determine the **maximum possible time** that each department can operate **without critical systems**.
 - ✓ **Critical systems** are defined as systems that are required to support the **different** operations that take place in an organization.
- A common approach to establishing priorities is to
 - ✓ **List the critical needs** of each department,
 - ✓ **Identify the key processes** that need to take place in order to meet them, and
 - ✓ **Identify and rank the underlying processes and operations**.
- The operations and processes can be ranked into three levels of priority: essential, important, and nonessential.

Disaster Recovery Plan

4. Determining recovery strategies

- The recovery strategies need to be formulated to cover all aspects of the organization.
 - ✓ These aspects include **hardware, software, databases, communication channels, customer services, and end-user systems.**
 - ✓ There may be **written agreements with third parties**, such as vendors, to provide recovery alternatives in times of disasters. The organization should review such agreements, the duration of their cover, and their terms and conditions.
- By the end of this step, the disaster recovery team should have a solution to all that may be affected by a disaster in the organization.

Disaster Recovery Plan

5. Collecting data

- To facilitate the DR team going through a complete disaster recovery process, information about the organization should be collected and documented.
 - ✓ The relevant information that should be collected includes inventory forms, policies and procedures, communication links, important contact details, customer care numbers of service providers, and details of the hardware and software resources that the organization has.
 - ✓ Information about backup storage sites and backup schedules alongside their retention duration should also be collected.

Disaster Recovery Plan

6. Creating the disaster recovery plan

- The DR team should make a sound disaster recovery plan that is both comprehensive and practical.
 - ✓ The plan should be in a standard format that is easily readable and succinctly puts together all the essential information.
 - ✓ The response procedures should be fully explained in an easy-to-understand manner.
 - ✓ It should have a step-by-step layout and cover all that the response team and other users need to do when disaster strikes.
 - ✓ The plan should also specify its own review and updating procedure.

Disaster Recovery Plan

7. Testing the plan

- The applicability and reliability of the plan should thoroughly be tested to identify any challenges or errors that it may contain.
- Testing will provide a platform for the DR team and the users to **perform the necessary checks** and gain **a good understanding** of the response plan.
 - ✓ Some of the tests that can be carried include simulations, checklist tests, full-interruption tests, and parallel tests.
- It is imperative that the disaster recovery plan that a whole organization will rely on is proven to **be practical and effective**, for both the end users and the DR team.

Disaster Recovery Plan

8. Obtaining approval

- DR plan should be submitted to top management to get approved.
- The top management has to approve the recovery plan on two grounds:
 - ✓ 1st ground: The assurance that the plan is consistent with the organization's policies, procedures, and other contingency plans
 - For instance, a DR plan that can only bring back online services after a few weeks might be incompatible with the goals of an e-commerce company.
 - ✓ 2nd ground: The plan is subject to annual reviews
 - The top management has to determine the adequacy of the plan and evaluate the compatibility of the plan with the organization's goals.

Disaster Recovery Plan

Maintaining the plan

- **A good disaster recovery plan must be updated often:** For example, the WannaCry hit over 150 countries within a short time span.
- This clearly shows that disaster recovery plans should be **updated based on need** rather than on a rigid schedule.
- The last step in the disaster recovery process should be the setting up of an updating schedule. This schedule should also make provisions for updates to be done when they are needed, too.

Disaster Recovery Plan

- Challenges (in disaster recovery planning processes)

- The lack of approval by the top management

- ✓ The top management takes the disaster recovery planning as a mere drill for a fake event that might never happen does not prioritize the making of such a plan.

- The incompleteness of the **recovery time objective (RTO)**

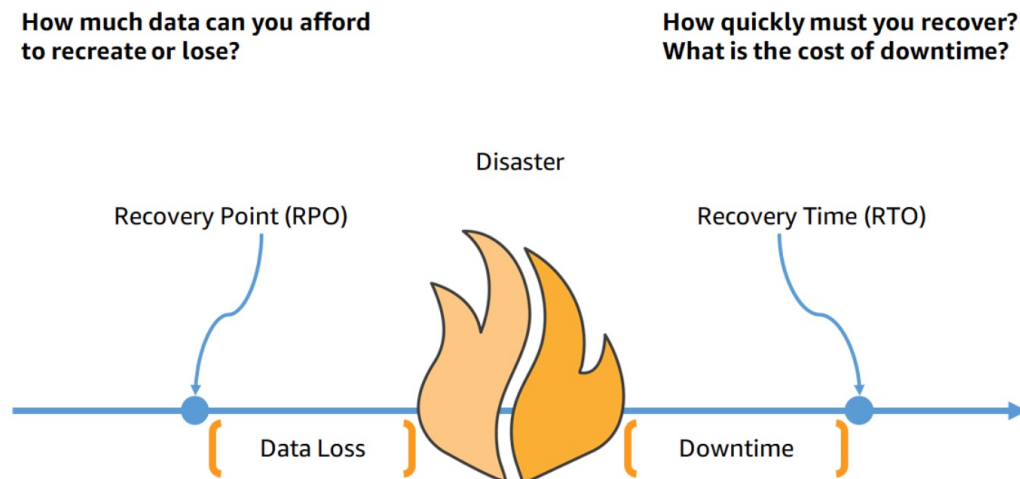
- ✓ RTOs are the key determiners of the maximum acceptable downtime for an organization. It is sometimes difficult for the DR team to come up with a cost-effective plan that is within the RTO.

- Outdated plans

- ✓ It is difficult to keep the disaster recovery plan updated. Outdated plans may be ineffective and may be unable to recover the organization when disasters caused by new threat vectors happen.

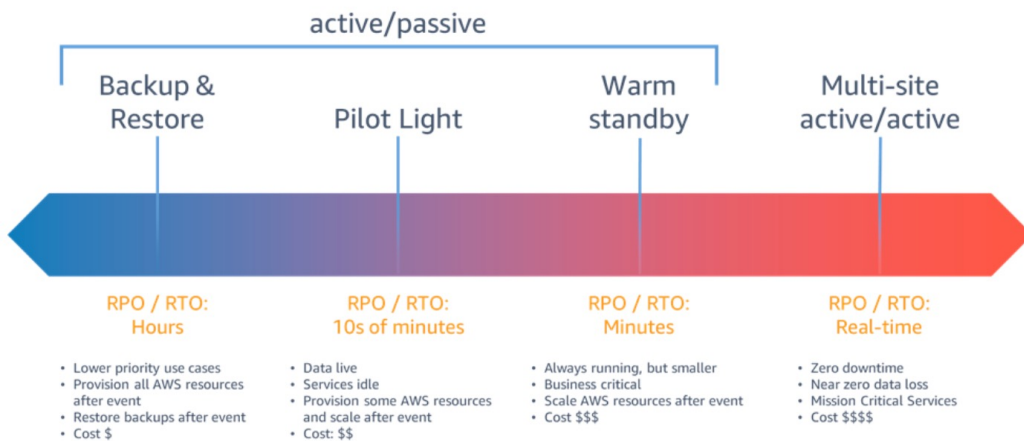
Recovery Objectives

- Two objectives used when creating disaster recovery plan
 - Recovery Time Objective (RTO) is the maximum acceptable delay between the interruption of service and restoration of service.
 - Recovery Point Objective (RPO) is the maximum acceptable amount of time since the last data recovery point.

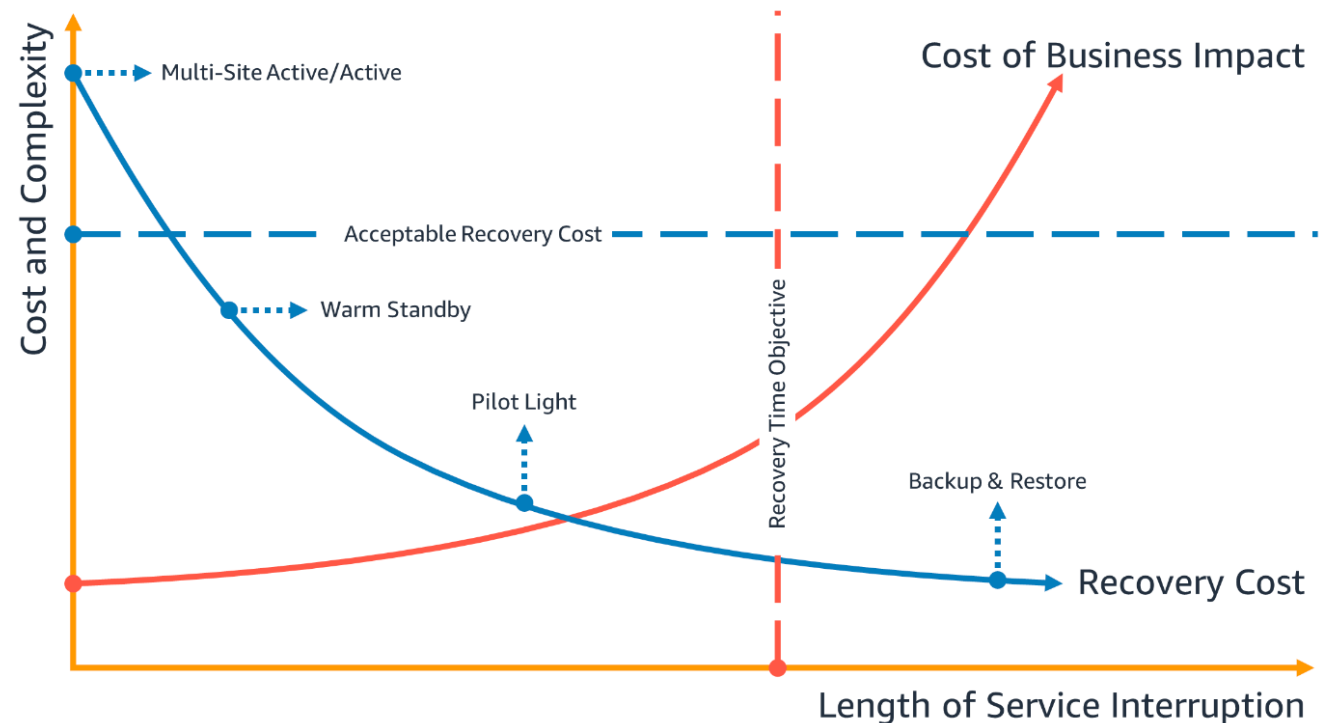


Recovery Objectives

- Relationship between RTO and business recovery strategy cost

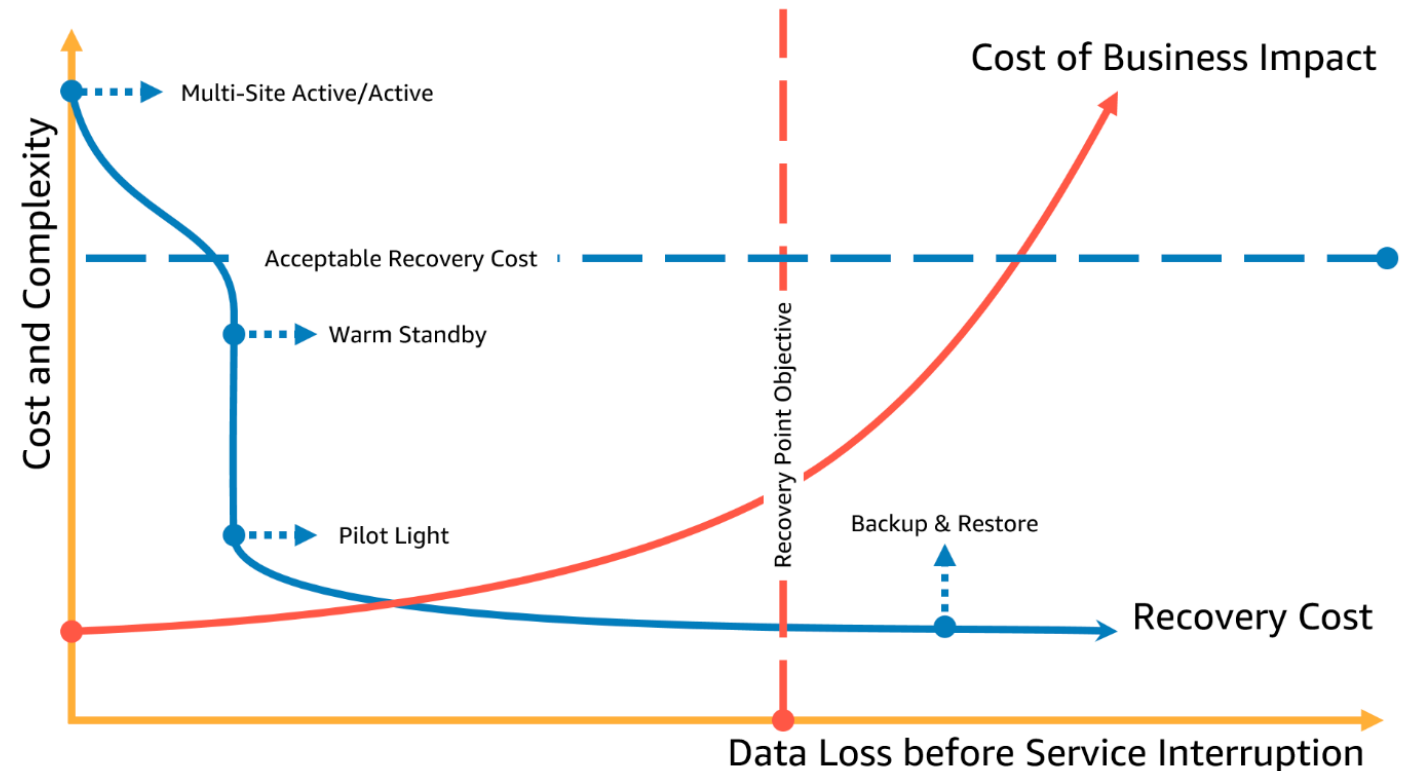


Disaster recovery strategies provided by AWS



Recovery Objectives

- Relationship between RPO and business recovery strategy cost/complexity



Live Recovery

- Need for live recovery

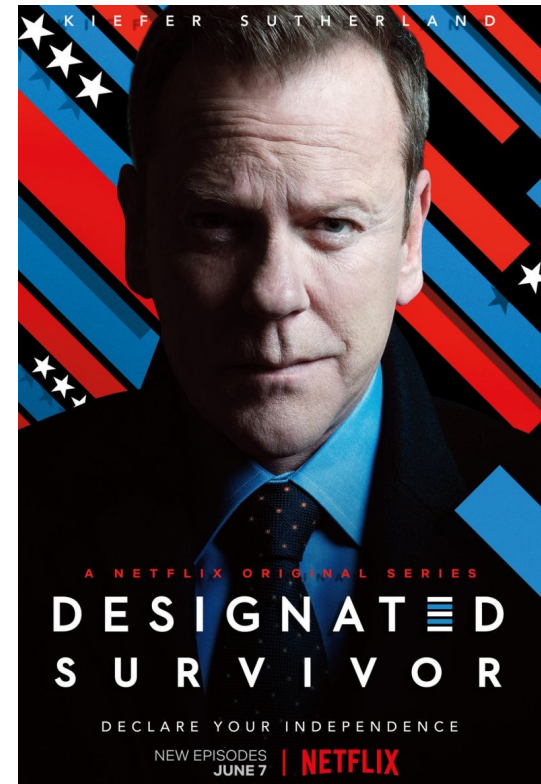
- Traditional recovery mechanisms mean that the affected system has to be taken offline, some backup files are installed, and then the system is brought back online.
- However, a disaster will affect **a system that is still in use**.
 - ✓ There are some organizations that have systems that cannot tolerate being taken offline for recovery to be done.
 - ✓ When the systems are structurally built in a way that they cannot be brought down for recovery

Live Recovery

- Two ways a live recovery can be done
 1. **Installing a clean system** with the right configurations and uncorrupted backup files on top of the faulty system
 - ✓ The end result is that the faulty system is gotten rid of, together with its files, and a new one takes over.
 2. **Using data recovery tools** on a system that is still online
 - ✓ This type of recovery is used when some valuable data should be recovered in the existing system.
 - ✓ The recovery tools may run an update on all the existing configurations to change them to the right ones; replace faulty files with recent backups.
 - ✓ This methods allows for the system to be changed without affecting the underlying files; allows recovery to be done without doing a complete system restore.

Contingency Plan

- **Contingency plan**
 - A contingency plan is a course of action designed to help an organization respond effectively to a significant future event or situation that may or may not happen. (Informally called “Plan B”)
- Contingency planning process involves:
 - Identification of risks that the IT infrastructure is subject to
 - Coming up with remediation strategies to reduce the impact of the risks significantly



Contingency Plan

- Need for contingency planning
 - Existence of many risks that face organizations, ranging from natural disasters to the careless actions of users
 - Impossibility to eliminate all the risks
- Sound contingency plan requirements
 - It should incorporate reliable execution plans and reasonably scheduled updating schedules.
 - There should be the integration between the contingency plan and other business continuity plans.
 - It should have recovery strategies as well as recovery time objectives.
 - Exercise, training, and updating tasks should be developed.

Contingency Plan

- Need for IT contingency planning process
 - IT contingency planning helps organizations to prepare for **future unfortunate events** to ensure that they are in a position to respond to them timely and effectively.
 - Even under the unfortunate events such as hardware failure, cybercrime, natural disasters and unprecedented human errors happen, an organization needs to keep going, even after suffering significant damage.
- IT platforms that a contingency plan must address:
 - Workstations, laptops, and smartphones
 - Servers and Websites
 - The intranet and Wide area networks
 - Distributed systems (if any)
 - Server rooms or firms (if any)

Contingency Plan

- Five steps of IT contingency planning process
 1. Development of the contingency planning policy
 2. Conducting business impact analysis
 3. Identifying the preventive controls
 4. Developing recovery strategies
 5. Plan maintenance

Contingency Plan

1. Development of the contingency planning policy

- A good contingency plan must be based on a clear policy that defines the organization's contingency objectives and establishes the employees responsible for contingency planning.
- All the senior employees should be included in developing a site-wide, agreed-upon contingency planning policy that outlines the roles and responsibilities of contingency planning.

Contingency Plan

- The **key elements** the contingency planning policy must contain:
 - ✓ The **scope** that the contingency plan will cover
 - ✓ The **resources** required
 - ✓ The **training needs** of the organizational users
 - ✓ **Testing, exercising, and maintenance** schedules
 - ✓ **Backup** schedules and their storage locations
 - ✓ The definitions of the **roles and responsibilities** of the people that are part of the contingency plan

Contingency Plan

2. Conducting business impact analysis

- **A business impact analysis (BIA):** An analysis that predicts the consequences of disruption of a business function and process and gathers information needed to develop recovery strategies.
- **Benefits of conducting BIA**
 - ✓ It will help the contingency planning coordinators to characterize an organization's system requirements and their interdependencies.
 - ✓ It will correlate different systems with the critical services that they offer.
 - ✓ From the information obtained by BIA, the organization can identify the individual consequences of a disruption to each system.

Contingency Plan

- Three steps of BIA:
 - 1) Identifying the critical IT resources
 - 2) Identifying disruption impacts
 - 3) Developing recovery priorities



Contingency Plan – BIA Part

1) Identifying the critical IT resources

- The resources that support the core business processes, such as payroll processing, transaction processing, or an e-commerce shop checkout, are critical.
- The critical resources are usually the servers, the network, and the communication channels
 - ✓ Different businesses may have their own distinct critical resources.

Contingency Plan – BIA Part

2) Identifying disruption impacts

- For each of the identified critical resources, the business should identify their allowable outage times.
 - ✓ **The maximum allowable outage time** is the period of unavailability of a resource within which the business will not feel major impacts.
 - ✓ Different organizations will have different **maximum allowable outage times** depending on their core business processes.
 - ✓ The organization needs to observe its key processes and come up with estimates of the **maximum allowable outage time** that they can remain unavailable without having adverse consequences.
 - ✓ The best outage time estimates should be obtained by balancing the cost of a disruption and the cost of recovering an IT resource.

Contingency Plan – BIA Part

3) Developing recovery priorities

- From the information that the organization will have collected from the preceding step, it should prioritize the resources that should be restored first.
 - ✓ The most critical resources, such as communication channels and the network, are almost always the first priority. However, this is still subject to the nature of the organization.
 - ✓ Some organizations may even prioritize the restoration of production lines higher than the restoration of the network.

Contingency Plan

3. Identifying the preventive controls

- Some of the impacts that are uncovered in the BIA could be mitigated through preventative measures which detect, deter, or reduce the impact of disruptions to the system.
- If preventative measures are feasible and at the same time not very costly, they should be put in place to assist in the recovery of the system. However, at times, it may become too costly to put in place preventative measures for all types of disruptions that may occur. There is a very wide range of preventative controls available, from those that prevent power interruptions to those that prevent fires.

Contingency Plan

4. Developing recovery strategies

- **Developing recovery strategies:** The strategies that will be used to restore the IT infrastructure in a quick and effective manner after a disruption has occurred.
- Recovery strategies must be developed with a focus on the information obtained from the BIA.
 - ✓ There are several considerations that have to be made while choosing between alternative strategies, such as costs, security, site-wide compatibility, and the organization's recovery time objectives.
- Recovery strategies should also consist of combinations of methods that are complementary and cover the entire **threat landscape** facing an organization.

Contingency Plan

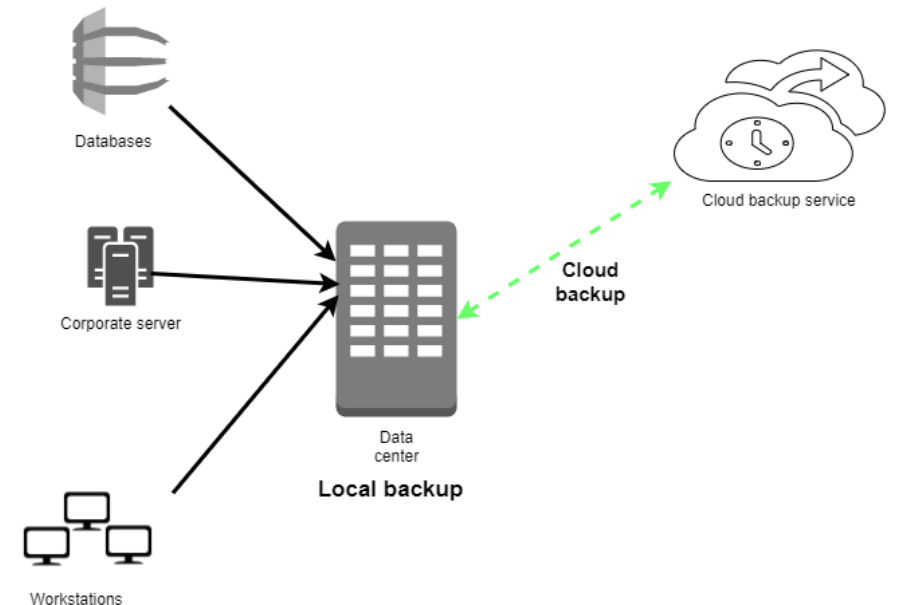
- Backups

- Occasionally, the data contained in systems should be backed up. The backup intervals should, however, be short enough to capture reasonably recent data.
- The organization can easily recover the system from the backup in the event of a disaster that leads to the loss of the systems and the data therein.
 - ✓ It can reinstall the system and then load the most recent backup and get back on track.
- Data backup policies should be created and implemented.
 - ✓ The policies at the very least should cover the backup storage sites, naming conventions for the backups, the rotation frequency, and the methods for the transmission of the data to backup sites.

Contingency Plan

➤ Cloud backups

- ✓ The advantages: cost, reliability, availability and size
 - Since the organization does not buy the hardware or meet the maintenance costs of the cloud servers, it is cheaper.
 - Since cloud backups are always online, they are more reliable and available than backups on external storage devices.
 - The flexibility to rent as much space as one wants gives the advantage of storage capacity that grows with demand.
- ✓ The disadvantages: privacy and security



Contingency Plan

- Alternative sites
 - There are some disruptions that have long-term effects. These cause an organization to close operations at a given site for a long period.
 - The contingency plan should provide options to continue business operations in an alternative facility.
 - Categorization based on ownership
 - ✓ Sites owned by the organization
 - ✓ Sites acquired through agreements with internal or external entities
 - ✓ Sites commercially acquired through leases

Contingency Plan

➤ Categorization based on readiness to continue business operations (in ascending order of their readiness to continue with operations):

✓ Cold sites

- Have the supportive resources ready
- Require the installation of IT equipment and telecommunication services

✓ Warm sites

- Partially equipped and kept in a ready state
- Require preparation through staffing to be operational

✓ Hot sites

- Adequately equipped and staffed to continue with IT operations

✓ Mirrored sites

- Exact replicas of the main sites

Contingency Plan

- Equipment replacement
 - Once critical hardware and software were damaged by a disaster, the organization will have to make arrangements to have these replaced.
 - There are three options that the contingency plan may go for:
 - ✓ A vendor agreement: The vendors are notified to respond to a disaster with the necessary replacements.
 - ✓ An equipment inventory: The organization purchases replacements for critical IT equipment in advance and safely stores them. Once a disaster strikes, the replacement equipment may be used for replacements in the main site or installed in the alternative sites to re-establish the IT services.
 - ✓ Any existing compatible equipment as the replacement for damaged equipment: This option includes borrowing equipment from alternative sites.

Contingency Plan

- Plan testing, training, and exercising
 - Testing: Tests of contingency plans must focus on
 - ✓ the speed of recovery from backups and alternative sites,
 - ✓ the collaboration between recovery personnel,
 - ✓ the performance of recovered systems on alternative sites,
 - ✓ the ease of restoring normal operations.
 - Testing should be done in a worst-case scenario and should be conducted through **classroom exercises** or **functional exercises**.

Contingency Plan

- Plan testing, training, and exercising
 - Training
 - ✓ Theoretical training is used to supplement practical training and reinforce what the employees learned during the exercises.
 - ✓ Training should be conducted annually at the very least.
 - Exercising
 - ✓ **Classroom exercises** are the least costly, as the employees are mostly walked through the recovery operations in class before doing a practical exercise.
 - ✓ **Functional exercises**, on the other hand, are more demanding and require a disaster to be mimicked and the staff to be taught practically how they can respond.

Contingency Plan

5. Plan maintenance

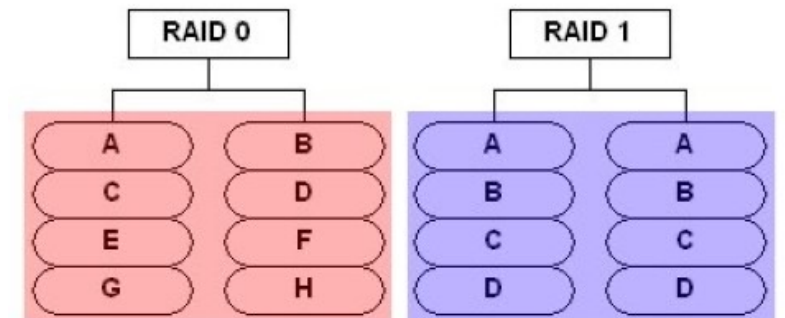
- The contingency plan needs to be maintained adequately so that it can respond to an organization's current risks, requirements, organization structure, and policies.
- The plan needs to be reviewed regularly and updated if necessary, and the updates should be documented.
- The review should be done at least annually and all the changes noted should be effected within a short period of time. This is to prevent the occurrence of a disaster that the organization is not yet prepared for.

Best Practices for (Disaster) Recovery

- **Best practices** for better results of recovery
 - Having an offsite location to store archived backups.
 - ✓ The cloud is a ready solution for safe off-site storage.
 - Keeping record of any changes made to the IT infrastructure to ease the process of reviewing the suitability of the contingency plan against the new systems
 - Having proactive monitoring of IT systems so as to determine when a disaster is occurring early enough and to start the recovery process.

Best Practices for (Disaster) Recovery

- Implementing fault-tolerant systems that can withstand a certain degree of exposure to a disaster.
 - ✓ Implementing a redundant array of independent disks (RAID) for servers is one way of achieving redundancy. It is also good to test the integrity of the backups that are made to ensure that they have no errors.
- Regularly testing the process of restoring a system from backups
 - ✓ All the IT staff need to be fully knowledgeable about this.



Source: <https://www.datanumen.com/blogs/5-main-differences-raid-0-raid-1/>